NikahMate: Final Company Handover Report

Source-code audit and remediation, verified 8 November 2026. Local evidence only: nothing has been run on hosted Supabase, on EAS or on a device.

Repository	`MuhammadZeeshanAkhtar/Rishta` (pnpm monorepo: Expo app, Fastify API, Supabase migrations)
Baseline	NikahMate Code Review Report, 28 October 2026 (SHA-256 `ec75ef9b…295c1`), and every later security review
Approved candidate	`4525c64721e73407e51e8aa4345ecc6ada3db59a` (unchanged)
Work reviewed	Branch `remediation/code-review-verification`: 32 modified and 8 new files on top of the candidate, **uncommitted**

2,549
tests passed (0 failed, 0 skipped)

32 of 32 caught
mutation checks on security safeguards

0 / 1 / 3
critical / high / moderate advisories (none in the API)

21 / 21
Expo Doctor checks

Source-code handover: READY, with two conditions

Every check that can run locally has run and passed, and no known, fixable defect remains in the repository. The conditions:

- **Commit this remediation first.** The 40 changed files are uncommitted and await the owner's approval. The candidate `4525c64` alone lacks the erasure, retention-hold and deep-link fixes.
- **Hand it over privately.** The GitHub repository is currently public and `main` is unprotected. Visibility and transfer are the owner's decision.

Production release: BLOCKED

Blocked on steps outside the repository: hosted migrations and `verify:db`, Supabase Dashboard settings, an `https://` API host, an EAS build and device testing, and counsel's review before erasure is scheduled (section 9).

1. Verification summary

Check	Command or method	Result
Full test suite	`pnpm test` (6 packages)	2,549 passed, 0 failed, 0 skipped
Formatting	`pnpm format:check`	clean
Lint	`pnpm lint`	exit 0
Typecheck	`pnpm typecheck`	exit 0, 0 errors
API production build	`pnpm build` in services/api	exit 0 (353,161 bytes)
Web production export	`expo export --platform web` with placeholder https addresses	exit 0
Web security policy step	`apply-web-csp.mjs`	written for https addresses; refuses the developer .env (exit 2)
Android JS export	`expo export --platform android`	exit 0 (5,084,043-byte bundle)
Bundle scans (web, Android)	localhost, emulator address, service_role, secret keys, JWTs, local .env values	none found

Check	Command or method	Result
Expo Doctor	`expo-doctor`	21 of 21 passed
Secret scan	Key, token, JWT and connection-string patterns over every file and all git history. The only matches are 6 connection-string examples: documented placeholders and test fixtures pointing at example or local hosts	no credentials found
CI secret guard	Pattern for committed tool keys	no match
Lockfile	`pnpm install --frozen-lockfile`	exit 0
Dependency audit	`pnpm audit`	0 critical, 1 high, 3 moderate
Mutation checks	Each safeguard broken in a scratch copy, its tests run, file restored by hash	32 of 32 caught

2. Test results

Package	Test files	Tests passed	Failed	Skipped
packages/domain	6	254	0	0
packages/db (migrations, row security, grants)	21	622	0	0
packages/i18n	1	14	0	0
packages/api-client	4	45	0	0
apps/mobile	14	273	0	0
services/api (routes, verify:db, Data API, erasure, workflows)	54	1,341	0	0
Total	**100**	**2,549**	**0**	**0**

One complete run of `pnpm test` on the final code, exit 0. Database suites apply every migration to a real Postgres (PGlite) in-process. Migration and verification coverage includes fresh install, release order (0026-0033, deploy, 0034-0035), live upgrade, `verify:db` end to end, and the Data API suite over all 58 tables.

3. Mutation tests

Each safeguard was deliberately broken in a scratch copy of the repository and its tests were run. "Caught" means at least one test failed. Every file was restored and checked by hash; the repository itself was never modified.

Set	Safeguard broken	Outcome	Tests
AUDIT (this round)	retention hold ignored by the erasure gate	CAUGHT	1 failed | 37 skipped (38)
AUDIT (this round)	database erases instead of holding on a retention hold	CAUGHT	1 failed | 37 skipped (38)
AUDIT (this round)	erasure tool skips a retention hold instead of holding	CAUGHT	1 failed | 37 skipped (38)
AUDIT (this round)	holds table without forced row security	CAUGHT	1 failed | 22 skipped (23)
AUDIT (this round)	members granted read access to holds	CAUGHT	1 failed | 37 skipped (38)
AUDIT (this round)	verify:db no longer checks who can reach holds	CAUGHT	1 failed | 22 skipped (23)
AUDIT (this round)	deep-link guard lets malformed encoding through	CAUGHT	5 failed | 7 passed (12)

Set	Safeguard broken	Outcome	Tests
AUDIT (this round)	deep-link guard without the length cap	CAUGHT	1 failed | 11 skipped (12)
AUDIT (this round)	router hook bypasses the guard	CAUGHT	1 failed | 11 skipped (12)
AUDIT (this round)	a route added with no auth gate	CAUGHT	1 failed | 69 skipped (70)
REVIEW	grace floor removed	CAUGHT	1 failed | 37 skipped (38)
REVIEW	family permissions left granted	CAUGHT	1 failed | 37 skipped (38)
REVIEW	files deleted before the database step	CAUGHT	1 failed | 37 skipped (38)
REVIEW	only the rows' paths deleted, folder not listed	CAUGHT	1 failed | 37 skipped (38)
REVIEW	no timeout on Storage and Auth calls	CAUGHT	1 failed | 37 skipped (38)
REVIEW	skipped requests use up the limit	NOT APPLIED: pattern not found	
REVIEW	a held outcome treated as erased (race)	CAUGHT	1 failed | 1 passed | 36 skipped (38)
REVIEW	the API accepts the erasure key	CAUGHT	1 failed | 37 skipped (38)
REVIEW	a failure code printed as the message	CAUGHT	1 failed | 37 skipped (38)
FINAL VERIFICATION	conversation left shown as active	CAUGHT	1 failed | 37 skipped (38)
FINAL VERIFICATION	interest note left visible	CAUGHT	1 failed | 37 skipped (38)
FINAL VERIFICATION	sign-in link deleted again (old token can bootstrap)	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	sensitive fields (phone, email) left behind	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	a staff account erased	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	an open report no longer holds the erasure	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	erasure inside the grace period	NOT APPLIED: pattern not found	
ORIGINAL ERASURE SET	members allowed to erase	CAUGHT	1 failed | 3 passed | 34 skipped (38)
ORIGINAL ERASURE SET	storage failure ignored	CAUGHT	1 failed | 37 skipped (38)

Set	Safeguard broken	Outcome	Tests
ORIGINAL ERASURE SET	sign-in deleted before the files	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	the conversation not closed for the other person	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	read-back shows a cancelled request	CAUGHT	1 failed | 37 skipped (38)
ORIGINAL ERASURE SET	family SLA warns twice	CAUGHT	1 failed | 1 passed | 36 skipped (38)
GRACE CHECK REMOVED	36 skipped (38) | erasure inside the grace period	CAUGHT	2 failed
LIMIT CHECK RE-RUN (pattern updated)	37 skipped (38) | skipped requests use up the limit	CAUGHT	1 failed

32 of 32 applied mutations caught. 2 earlier mutation patterns no longer matched text that this round revised (the grace-period line and the skip condition). Each was re-run with an updated pattern and caught: see "GRACE CHECK REMOVED" and "LIMIT CHECK RE-RUN". After the runs, the scratch copy matched the repository byte for byte.

4. Security audit

What was checked across the whole repository

- **Authentication:** every registered route answers 401 without a token, except the 5 public ones (new test sweeps all routes).
- **Authorization:** every route refuses a suspended, banned, deactivated or pending-deletion account except named lifecycle routes (existing sweep).
- **Data API:** a member JWT can neither read nor write any of the 58 public tables. Row security is enabled and forced on all 58.
- **Database functions:** erasure, holds and the SLA sweep are server-only, checked for `anon`, `authenticated` and `api_member` by `verify:db`.
- **SQL injection:** every dynamic SQL builder uses fixed column maps with parameterised values.
- **Request validation:** no route reads a body without a schema.
- **Logging:** no personal data in logs, and redaction is configured.
- **Secrets:**
  - None in any file or anywhere in git history. Only `.env.example` files are tracked, and they hold no values.
  - The API refuses to start if a service-role or tool key is in its environment.
- **Client bundles:** no localhost or emulator address, key or token. The web security policy refuses local addresses.

Remaining vulnerabilities and risks

Severity	Issue	Exposure	Status
Medium	Closed-report evidence (profile, photos) is erased with the account; ERD E1 asks for 5-year evidence and snapshots are not built	Any erasure of a member with a closed report	Counsel decision
Medium	Erasure Storage list/delete and Auth admin calls tested only against stand-ins; acceptance of newer sb_secret_ keys unconfirmed	First real erasure run. Worst case is incomplete deletion; guards stop it touching other members	Hosted rehearsal required
Low	decode-uri-component: a crafted link can freeze the web build's browser tab	Web only; native app mitigated	Documented
Low	glob / minimatch advisories in build and lint tooling	Not shipped; no untrusted input	Documented
Low	Concurrency (B1, B17) verified by code inspection; the test database is single-connection	Simultaneous decisions	Needs multi-connection test (L12)
Low	No staff screen for retention holds or held requests	Process only: supervised SQL	Company process
Low	After erasure, the same email can register a new account	Ban evasion is limited: banned members are never erased automatically	Company policy
Info	Public repository with unprotected main	Repository settings	Owner action

5. Dependency advisories and mitigations

Package	Severity	Where	Advisory	Mitigation
decode-uri-component 0.2.2	High Moderate	App: expo-router > query-string 7	Denial of service on malformed percent-encoding (GHSA-qr28-fpjm-wq7f, GHSA-vcc3-ghjq-m6fr)	**Mitigated on native.** The fix is ES-module only, which query-string 7 cannot load. `app/+native-intent.ts` sends malformed or oversized deep links home before parsing. Measured: about 600 crafted characters froze the decoder for 5.4 s; the guard refuses them in under 50 ms. Web build not covered.
glob 13.0.6	Moderate	Expo tooling (@expo/fingerprint)	Timeout-signal bypass (GHSA-3g3m-2fjr-6pw4)	Fixed only in 14.x, outside the range the package declares. Tooling only.
minimatch 10.2.6	Moderate	ESLint (typescript-eslint)	Pattern amplification DoS (GHSA-g3hv-75wg-m249)	Fixed only in 11.x. Lint patterns are the project's own.

Every package listed in the 28 October report is upgraded. None of the remaining advisories is in the API's production tree. expo-font was added as a direct dependency (Expo Doctor: "may crash outside of Expo Go" without it).

6. Legal hold and account erasure: verified together

- **Mechanism (migration 0035):**
  - `public.account_retention_holds` has forced row security and no member access.
  - `app.erasure_blocker` answers `retention_hold` while a hold is unreleased.
  - `app.erase_account` then holds the request, telling the member only that "a legal review" must finish.
  - Cancelling and asking again does not clear the hold.
- **Erasure tool:**
  - Dry run by default. It runs the database step first, uncommitted, then deletes every file in the member's own Storage folder (UUID and prefix guarded), then the sign-in, then commits.
  - Any failure rolls back, and the next run finishes the job. Calls time out after 30 s.
  - It prints request ids, steps and codes only.
- **Gate:** erasure is refused during the 30-day grace period (counted from the request as well as the stored date), and for staff accounts. An open report or a retention hold holds the request instead.
- **What the other person keeps:** the conversation (shown as ended), but not the erased member's notes. An old session token can no longer create an account.
- **verify:db:** checks that the three functions are server-only and that the holds table is present, forced and unreachable by members. A failure test exists for each check.
- **Evidence:**
  - 38 erasure tests, including holds surviving cancel-and-reask, a released hold, members unable to see holds, every failure point, and other members' files untouched.
  - `verify:db` failure tests.
  - The Data API suite over 58 tables.
  - Inventory tests in `verify-db.ts` and packages/db.
  - The mutation checks in section 3.
- **Not verified:** real Supabase Storage and Auth. Erasure must not be scheduled until counsel reviews ERD E1 and a hold process is agreed.

7. Findings matrix (PDF baseline and later reviews)

Fixed: implemented and pinned by tests. **Fixed in repo:** correct in code and migrations, but must be applied or confirmed on the hosted project. **Partial / Open:** product limitations, not bugs.

ID	Status	Evidence	Still needed
B1	Fixed	Family decision only while pending review; approval needs every review; database trigger. Tests incl. workflows (3 flows).	Hosted migrations
B2	Fixed	Invite link shared and accepted. Tests incl. workflows (B2).	Link not emailed/texted (provider); deep link untested on a device
B3	Fixed	Discoverability rule applied in discovery; incognito enforced in the database.	Company to confirm decision 1 reading of "liked"
B4	Fixed	Pending and maybe-later answered; sender can withdraw. Tests incl. workflows (B4).	
B5	Fixed	Finalize only from pending; queued for a moderator; no auto approval.	Automated image screening not built (optional)
B6	Fixed	Submit to pending; edits re-reviewed; date of birth locked with an audited correction flow.	
B7	Fixed in repo	Text-only member messages; 0027 revoke; 0034 removes direct table access.	Hosted migrations; Dashboard exposure setting
B8	Fixed	Dependencies listed in the report all upgraded.	
B9	Fixed	Rate limit keyed on the verified subject; per-route send limits.	
B10	Fixed	Keyset cursors on every member list.	
B11	Fixed	Abandoned uploads stop counting after the URL lifetime.	Scheduled byte removal needs a Storage key
B12	Fixed	Originals re-encoded at finalize; older originals withheld until cleaned.	Run legacy-content (company)
B13	Fixed	Primary photo must be approved (route and constraint).	
B14-B16	Fixed	UUID validation and error mapping; Storage detail logged only; closed threads refuse stage changes.	
B17	Fixed	Row lock on respond.	Concurrent test needs multi-connection Postgres (L12)
B18	Fixed in repo	Redirect chosen per platform; another-device link reported clearly.	Supabase redirect URLs (Dashboard)
B19-B25	Fixed	One test per item, named by ID.	
B26	Fixed in repo	Quieter service-role trace; one notification per conversation; retention task.	A scheduler
L1	Partial	Staff console with queues, actions, audit, MFA requirement, rank rules.	No identity/selfie/phone verification tooling; no cases or evidence snapshots
L2	Open	Calls, voice notes, media: not built.	Provider decision
L3	Fixed in repo	Storage policy and grants (0031, 0033).	Verify on real Storage
L4	Fixed	GET /profiles/{userId} with field visibility.	
L5	Open	Marriage journey and AI layer: not built.	Product decision

ID	Status	Evidence	Still needed
L6	Partial	Family review layer end to end; 72-hour SLA sweep schedulable.	No supervised chat, family in chat or quorum
L7	Partial	Deletion request, cancel, read-back; deactivation; erasure tool with retention holds.	Schedule erasure after counsel; hold process; export; AAB; store policies
L8	Partial	Push tokens and preferences.	Delivery (provider decision)
L9	Fixed	Contact details filtered from interest notes.	
L10	Partial	111 of 129 documented operations served; 18 marked not implemented and kept in step by a test.	Build or drop the 18
L11	Partial	maintenance and account-erasure ready to schedule.	A scheduler
L12	Partial	2,549 automated tests incl. contract, workflow, release-order, live-upgrade suites.	No device E2E, component, load, penetration or multi-connection tests
N1	Fixed in repo	API status gate and restrictive row security (0032).	Hosted migrations
N2	Fixed in repo	Owner-only reads (0032) and the 0034 cutover.	Hosted migrations

8. Bugs, limitations and blockers (separated)

Known bugs in the repository

None known and fixable. Areas with no automated coverage are listed under L12: device, component, load, penetration and multi-connection testing.

Product limitations (not bugs)

- L1: no identity, selfie or phone verification tooling; no cases.
- L2: no calls, voice notes or media.
- L5: no marriage journey or AI layer.
- L6: no supervised chat or family in chat.
- L7: no data export or AAB profile.
- L8: no push delivery.
- L10: 18 unbuilt operations.
- L11: no scheduler.
- No staff screens for retention holds.

9. Hosted deployment and company decisions still required

Area	Required before production
Database	Apply 0026-0033 (`migrate --through=20261106000033`), deploy the API, apply 0034-0035, run `verify:db`; test Realtime after 0034; set `DATABASE_SSL_CA`
Supabase Dashboard	Remove `public` from exposed schemas; check pg_graphql; add redirect URL `nikahmate://auth/callback`; staff MFA; PITR and a restore test
Hosting	Choose a host; deploy the API at an https address; keep both tool keys out of its environment
Mobile	Expo login and owner account; EAS environment values; first EAS build (signing key in EAS); real-device testing; APK or AAB
Erasure	Counsel review of ERD E1; legal-hold process; hosted rehearsal on a copy; scheduler for maintenance and erasure
Store and legal	Privacy policy, data-safety form, web deletion page, age rating

Area	Required before production
Company decisions	Suspended-counterpart display; decision 1 reading; legacy content; push/SMS/call providers; re-registration policy; evidence retention
Operations	Sentry DSN; mobile crash reporting; uptime monitoring; GitHub branch protection, secret scanning, repository visibility and transfer

The version running in production is unknown. Nothing was deployed, migrated or changed on any hosted service during this work.

10. Changed files (against candidate 4525c64)

This final audit round

- Retention holds: migration 0035, the erasure tool, `verify:db`, inventories and tests.
- Deep-link guard for `decode-uri-component`.
- `expo-font` dependency.
- No-token sweep over every route.
- Documentation corrections: test counts, the OpenAPI numbers (111 paths, 129 operations, 82 schemas) and stale status rows.

Modified (32)

File	Lines	Change
`.github/workflows/ci.yml`	+3 / -3	Secret guard also refuses a committed erasure-tool key
`CODE_REVIEW_FIX_TRACKER.md`	+68 / -20	Verified finding-by-finding status; dependency and deployment sections corrected
`DATABASE_MIGRATION_REPORT.md`	+32 / -0	0035: table, functions, order, safety, rollback
`README.md`	+20 / -20	Current test, migration, table and OpenAPI counts; stale deployment row fixed
`apps/mobile/app.json`	+2 / -1	expo-font config plugin (added by Expo's installer)
`apps/mobile/app/(app)/(tabs)/discover.tsx`	+4 / -1	Already-sent interest leaves the feed instead of showing an error
`apps/mobile/package.json`	+1 / -0	expo-font ~57.0.4 as a direct dependency (Expo Doctor)
`apps/mobile/src/appWorkflows.test.ts`	+19 / -0	Tests for the Discover outcome
`apps/mobile/src/discovery/useDiscoverFeed.ts`	+3 / -0	forget(): remove a card locally
`apps/mobile/src/session/SessionProvider.tsx`	+11 / -1	Reads an open deletion request back after a restart
`docs/ANDROID_APK_BUILD.md`	+14 / -12	CLI without installation; code/API match; Expo Doctor 21/21
`docs/CODE_REVIEW_COMPLETION_REPORT.md`	+4 / -0	Marked as the superseded 5 November snapshot
`docs/HANDOVER.md`	+15 / -15	Current test results and status pointers
`docs/KNOWN_LIMITATIONS.md`	+17 / -12	Erasure, holds, SLA sweep, Discover
`docs/MAINTENANCE.md`	+7 / -3	SLA sweep task; erasure scheduling
`docs/PRODUCTION_SECURITY.md`	+90 / -26	Erasure, holds, keys, evidence question, dependency mitigations
`docs/openapi.yaml`	+17 / -3	GET /me/delete; erasure described
`packages/api-client/src/client.ts`	+12 / -2	getAccountDeletion()
`packages/db/src/migrations.test.ts`	+4 / -2	Table inventory: 58 tables, all with forced row security
`pnpm-lock.yaml`	text diff: +3 lines	Three lines: the expo-font importer entry
`services/api/package.json`	+1 / -0	account-erasure script
`services/api/scripts/account-security-checks.ts`	+51 / -4	verify:db: api_member checked; erasure functions and holds table server-only

File	Lines	Change
`services/api/scripts/maintenance.ts`	+17 / -2	Family review SLA sweep task
`services/api/scripts/verify-db.ts`	+2 / -0	Expected-table inventory includes account_retention_holds
`services/api/src/auth/plugin.ts`	+1 / -0	GET /me/delete allowed for a restricted account
`services/api/src/config.ts`	+7 / -2	API refuses to start with either tool key in its environment
`services/api/src/routes/me.ts`	+32 / -0	GET /me/delete
`services/api/test/account-security.test.ts`	+19 / -0	Every route refuses a request with no token
`services/api/test/client-contract.test.ts`	+3 / -1	getAccountDeletion contract
`services/api/test/data-api-security.test.ts`	+2 / -1	Member JWT covers 58 tables
`services/api/test/maintenance.test.ts`	+1 / -0	New maintenance task
`services/api/test/verify-account-security.test.ts`	+62 / -4	Break tests for every new verify:db check

New (8)

File	Size	Purpose
`apps/mobile/app/+native-intent.ts`	9 lines (new)	Deep-link guard hook for Expo Router
`apps/mobile/src/discovery/interestOutcome.ts`	13 lines (new)	Recognises "already sent"
`apps/mobile/src/navigation/safeDeepLink.test.ts`	72 lines (new)	12 tests, including the real exploit input
`apps/mobile/src/navigation/safeDeepLink.ts`	34 lines (new)	Malformed or oversized deep links go home (decode-uri-component)
`services/api/scripts/account-erasure.ts`	368 lines (new)	Erasure tool: dry run by default, database first, folder deletion
`services/api/test/account-erasure.test.ts`	1056 lines (new)	38 erasure, hold and SLA tests
`services/api/test/workflows.test.ts`	310 lines (new)	9 end-to-end tests for B1, B2, B4
`supabase/migrations/20261107000035_account_erasure.sql`	335 lines (new)	Erasure, retention holds, SLA sweep

Also new: `FINAL_REPORT.pdf` (this report), untracked.

11. Git status

Item	State
Branch	`remediation/code-review-verification` (no upstream)
HEAD	`4525c64721e73407e51e8aa4345ecc6ada3db59a`
Candidate `review/post-merge-security`	`4525c64721e73407e51e8aa4345ecc6ada3db59a`, unchanged
Backups preserved	`backup/pre-commit-snapshot` 5da4f3d; `review/phases-2-5-handover` 9f101be; local `main` 0de536f
origin/main (local ref)	`75d435b`

Item	State
Working tree	32 modified files (+541 / -135 lines), 8 new files (2,197 lines), plus this PDF; 0 staged; 0 stashed
Commits, pushes, merges, deploys, hosted migrations	None made

12. Not run, and not claimed

- Hosted migrations; a live `verify:db`; real Supabase Storage, Auth or MFA.
- A Gradle or EAS build, or any device.
- Multi-connection concurrency.
- Load and penetration tests.
- Counsel's review.